

SOC Interview Questions

1. What is port ?

Virtual communication endpoints used by computer to manage different type of traffic

Type :

- TCP (Transmission Control Protocol) : Reliable, connection-based (Two-way conversation)
- UDP (User Datagram Protocol) : Faster, connectionless (one-way fast)

Purpose : Keep each port for specific usage

2. TCP Handshake

Establish a reliable connection between two system using TCP with these step

- SYN : send synchronize packet as "I want to start connection "
- SYN-ACK : Server Response with "I got the message and here your response"
- ACK: Client replies to confirm and then connection is established

Purpose : prevent data loss, keep track with connection, allows TCP to provide reliable communication channel

3. Common Attacks

- Phishing
 - spear phishing : target specific person
 - whaling : target high-level individual
 - smishing : phishing over SMS text
 - vishing : phishing through voice call
- SQLi
 - Read sensitive data
 - modify or delete the data

- bypass login
- XSS
 - Stored XSS : code is saved on the server
 - Affect anyone view the page until the code remove from the server
 - Reflected XSS : code in the URL and run immediately
 - Customized URL payload link in which affect those who click it and can be phishing attack
 - DOM-based XSS : manipulate page structure through client-side code
- MITM
 - Listen and intercept the network or the connection from between both steal and modify
- Brute Force
 - Online : Tries login pages directly
 - Offline : cracks hashed passwords using tools
- DDoS
 - Flood the server or network with so much traffic it crashes or unusable. Type
 - Volumetric : huge mass of traffic
 - protocol-based : exploit flaws in protocol
 - Application layer : directly in to application layer 7
- Malware
 - Virus : need user action to make moves
 - worm : automatically replicated itself
 - Trojan : disguised as legitimate software
 - Spyware : monitor your activity in secret
 - Ransomware : encrypt everything and then demand ransom
- Credential Stuffing
 - Re-use the same password and username which they got from the breached server on the other platform hoping you use the same credentials
- Zero-Day exploits

- a vulnerability which even the developer don't know existed
- To Prevent
 - Use EDR or AV
 - Investigate the file name, hash, signature, high CPU usage and unauthorized access
 - Watch out for C2 attempts in logs
 - Stay up to date with threat intelligence feeds

- Look for suspicious behavior

Summary Table of Attacks

Attack Type	Goal	What to Monitor/Detect
Phishing	Steal credentials/data	Email logs, DNS requests
Malware	Damage/steal data	EDR alerts, suspicious files
SQL Injection	Steal/manipulate DB	Web logs, error responses
XSS	Run code in browsers	WAF logs, suspicious scripts
Brute Force	Guess passwords	Login attempts, failed logins
DDoS	Crash system	Traffic spikes, performance issues
MITM	Intercept communication	Duplicate IPs, ARP anomalies
Ransomware	Encrypt files	File access patterns, alerts
Credential Stuffing	Account takeover	Repeated login attempts
Zero-Day	Exploit unknown flaws	Behavior analysis, threat intel

4. What is EDR (Endpoint Detection Response)

it's like AV but smarter, faster and be able to detect the modern threats while not just known virus. It does :

- Detection
 - Response
 - Visibility
 - Investigation
 - Threat hunting
- Key Feature
- Real time monitoring
 - Threat detection using behaviour analytic
 - Automatic response
 - forensics

5. What is WAF (Web application firewall)

protects web applications by filtering and monitoring HTTP traffic. What is does :

- Block SQLi, XSS, file inclusion and more
- works at application layer 7 of OSI
- can be hardware-based or cloud-based

6. OSI model

There are 7 layers in total :

- Application
- Presentation
- Session
- Transport
- Network

- Data link
- Physical

Layer #	Name	Function Summary	Key Protocols/Technologies
7	Application	User-facing services and apps	HTTP, FTP, SMTP, DNS, Telnet
6	Presentation	Data format and encryption	SSL/TLS, JPEG, MPEG
5	Session	Managing connections (sessions)	NetBIOS, SAP, RPC
4	Transport	End-to-end data delivery	TCP, UDP
3	Network	Routing and addressing	IP, ICMP, OSPF
2	Data Link	Framing and MAC addressing	Ethernet, Wi-Fi (802.11), ARP
1	Physical	Transmission of bits over media	Cables, hubs, repeaters, NIC cards

Purpose : it's a conceptual framework which show how the data sent over the internet step by step to understand and procedure of applying security

Layer	Name	protocol	SOC
7	Application	User interface (HTTP, SMTP, FTP)	SQLi, XSS, Malware; Use WAFs here.
6	Presentation	Formatting & Encryption (SSL/TLS, JPEG)	Weak ciphers, SSL/TLS certificate anomalies.
5	Session	Managing connections (RPC, NetBIOS)	Session hijacking and cookie theft.
4	Transport	End-to-end delivery (TCP /UDP)	SYN floods , port scans, unusual port activity.
3	Network	Routing & IP addressing (IP, ICMP)	IP spoofing, ICMP/Ping floods.
2	Data Link	Local MAC addressing (Ethernet, ARP)	ARP poisoning , MAC flooding/spoofing.
1	Physical	Hardware & raw bits (Cables, Hubs)	Physical tampering, cable tapping, jamming.

7. Firewall

a network security device that monitors and controls incoming and outgoing traffic based on rules. Type

- Network Firewall : block or allow traffic by IPS, ports, protocols
- Host firewall : software in the endpoint
- NGFW : include IDS/IPS, DPI and app controls

Stateful Firewall (knows the connection based on rule and activity full on)

- Smarter and safer
- Blocks unexpected response from unknown sources
- useful for protocols like TCP

Stateless Firewall (Analyst every traffic each time before let it)

- Faster and simpler
- Less memory

- Simple for small networks
Hardware Firewall (network-based)
- Cisco ASA
- FortiGate
- Palo Alto NGFW
- Sophos XG Firewall
- Check point firewall
Software Firewall (Host-based)
- Windenfender
- pfSense
- IPTables / nftables
- Comodo firewall
- ZoneAlarm
NGFW cloud-based
- Azure Firewall
- AWS network firewall
- Cloudflare gateway
- palo alto prisma access

8. Vulnerability and exploits

- vulnerability is a weakness which can be exploit (outdate apache version)
- exploit : method used by attackers to take advantage of the vulnerability (send request for RCE)

9. Mail Relay

a mail server that forwards mail from one server to another

- Good relay : authenticated, controlled access
- Open relay : can be spamming which anyone can send

Purposes

- Load balancer
- Security filtering
- Backup
- Prevent by IP range, Domain and user credentials

10. NAC (network access control)

A security solution that controls who and what can access the network

- devices must meet the policies (AV on, OS updated)
- can quarantine, deny or allow based on the compliance

11. System Hardening

Reduce the vulnerabilities by securing system configurations

- Disabling unused services
- Up to date
- Change default passwords
- Removing unnecessary software
- enforcing strong password policies

12. Web Attacks and response

Common Web attack

- SQLi
- XSS
- CSRF
- File Inclusion
- Directory Traversal

Target :

- User input form
- cookies / sessions
- back-end databases
- authentication systems
- web server

1. The Web Attack "Big Five"

Attack	What It Is	Key Defense
SQL Injection (SQLi)	Inserting code to manipulate a database.	Parameterized Queries (Prepared Statements).
Cross-Site Scripting (XSS)	Injecting malicious scripts into web pages.	Input Sanitization & Content Security Policy (CSP).
CSRF	Tricking a logged-in user into doing an action.	Anti-CSRF Tokens .
File Upload	Uploading a script (e.g., .php) disguised as an image.	Rename files & store outside the web root.
Directory Traversal	Using <code>../</code> to access restricted system files.	Sanitize paths & restrict folder permissions.

2. The Defensive Concepts

You *must* be able to explain the difference between these pairs.

- **Sanitization vs. Validation:**
 - **Validation:** "Is this what I expected?" (e.g., "Is this a number?"). If not, **reject** it.
 - **Sanitization:** "I'll clean this for you." (e.g., converting `<` to `<`).
- **IDS vs. IPS:**
 - **IDS (Security Camera):** Detects and alerts. Out-of-band.
 - **IPS (Bodyguard):** Detects and **blocks**. In-line traffic.

- **False Positive vs. False Negative:**
 - **False Positive:** A "Good" thing flagged as "Bad" (Annoying/Waste of time).
 - **False Negative:** A "Bad" thing flagged as "Good" (**Dangerous/Catastrophic**).
-

3. The SOC Analyst Workflow

If asked, *"You see a suspicious alert, what do you do?"* use this 5-step flow:

1. **Triage:** Is this a real threat or a False Positive?
 2. **Investigate:** Check logs (SIEM/WAF), IP reputation, and the payload.
 3. **Scope:** How many systems are affected? Did the attacker succeed?
 4. **Containment:** Block the IP, disable the user account, or isolate the host.
 5. **Documentation:** Write the report and record **IOCs** (Indicators of Compromise).
-

4. Post-Exploitation: Persistence & Mimikatz

Interviewers love asking what happens **after** the initial breach.

- **Persistence:** How attackers stay in the system after a reboot.
 - *Methods:* Scheduled tasks, registry keys, new user accounts, or backdoors.
- **Mimikatz:** The "skeleton key" of Windows.
 - *Function:* Steals plaintext passwords and hashes from the computer's memory (RAM).
 - *Goal:* **Privilege Escalation** (becoming an Admin) or **Lateral Movement** (jumping to other servers).